

# Brightwater Analytics: Information Security Policy

*Fictional sample document for demo purposes.*

## Purpose

This policy protects the confidentiality, integrity and availability of Brightwater and customer data. It applies to all employees, contractors and systems. Violations may lead to disciplinary action.

## Data classification

Data is classified into four levels. Public data may be shared freely. Internal data is for employees only. Confidential data, such as contracts and financial reports, is shared on a need-to-know basis. Restricted data, which includes customer datasets and credentials, must be encrypted at rest and in transit and must never be copied to personal devices.

## **Passwords and authentication**

Passwords must be at least 14 characters long and must be stored in the company password manager. Multi-factor authentication is mandatory for email, source control, cloud consoles and the HR portal. Hardware security keys are required for anyone with production access.

## **Access control**

Access follows the principle of least privilege. Production access is granted for a maximum of 8 hours at a time through the access request tool and is logged. Managers review their team's access rights every quarter.

## **Devices**

Company laptops must use full-disk encryption, automatic screen lock after 5 minutes of inactivity, and must install security updates within 7 days of release.

## **Incident reporting**

Any suspected security incident, including lost devices, phishing emails that were clicked, or data sent to the wrong recipient, must be reported to the security team within 1 hour of discovery via the #security-incidents channel or security@brightwater.example. Do not try to investigate on your own and do not delete evidence.

## **Incident response**

The security team triages every report within 4 hours. Incidents involving personal data are assessed by the data protection officer, and where required, the relevant authority is notified within 72 hours.

## **Training**

All staff complete security awareness training during onboarding and then once a year. Simulated phishing exercises are run every quarter.